

1. Wolfenstein (Medium)

Flow giải bài:

.pcapng file và .dmp file

↓

TCP và HTTP Conversation → Follow TCP Stream 3

↓

Nimplant C2 Server → github source code → cách decrypt payload

↓

strings .dmp file → regex lọc chuỗi 16 ký tự → key

↓

Script python decode C2 traffic

↓

Decrypt... → IP, hostname, OS, PID, process

↓

Resquest POST lớn → decrypt → Base64 x2 → Gzip file

↓

Save .gz file → unzip → .png file → phần đầu flag

↓

Export Object với unreadable data → decrypt → PE file

↓

Strings PE file → Base64 encoded string → Decode Base64 → XOR BF → phần cuối flag

↓

Flag

Thử thách

10 lượt giải



wolfenstein

50

medium

👍 1 (100% liked) 🗨️ 0

Agent Hitler đang trong quá trình điều tra một vụ án.
Trong quá trình thực hiện nhiệm vụ, chiếc máy cá nhân
của đặc vụ này đã bị xâm nhập. Bạn có thể giúp điều tra
không.

Challenge cung cấp 2 file, 1 file lưu lượng mạng Register.pcapng và 1 file Mini Dump Register.dmp.

Phân tích file .pcapng em thấy conversation giữa nạn nhân và attacker được truyền chủ yếu qua TCP, em follow tcp stream tới stream 3.

```
GET /api/v1/telemetry/init HTTP/1.1
Connection: Keep-Alive
Accept: */*
Accept-Encoding: gzip
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/122.0.0.0 Safari/537.36
Host: 192.168.8.129:1836

HTTP/1.1 200 OK
Content-Type: application/json
Content-Length: 49
Server: NimPlant C2 Server
Date: Fri, 06 Mar 2026 10:14:52 GMT

{"id":"ceWcbxcl","k":"W2k0QDF6SFuWNG50d51/dAe="}

POST /api/v1/telemetry/init HTTP/1.1
Connection: Keep-Alive
Content-Type: application/json
Accept: */*
Accept-Encoding: gzip
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/122.0.0.0 Safari/537.36
X-Identifer: ceWcbxcl
Content-Length: 195
Host: 192.168.8.129:1836

{"data":{"c09pSvpdYUfdTXBEV3ReVwYCYLr8SPyM83TOSVXQDoL1sY9XmeFs0kaSz7aLGL5P7UX/Thq81I/trF4yDE79YC9p7BRHcAAUrzYEQkEFHpjOIB1rbUIR4Pggdi7FkHu4yRYkPaFSME5ZRRR+rBDSNuJkfw6ev5U+EdoYHmp2pT3rwPKyOuOQ=="}}

HTTP/1.1 200 OK
Content-Type: application/json
Content-Length: 16
Server: NimPlant C2 Server
Date: Fri, 06 Mar 2026 10:14:52 GMT

{"status":"OK"}

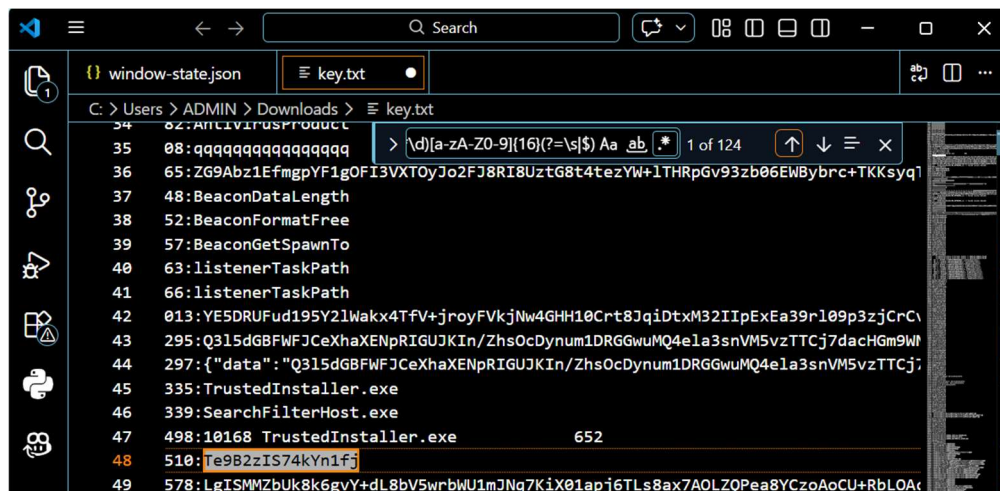
GET /api/v1/telemetry/sync HTTP/1.1
Connection: Keep-Alive
Accept: */*
```

Xác định được thông tin truyền đi giữa 2 máy được mã hóa với Nimplant C2. Qua source code của Nimplant C2, đặc biệt là Nimplant/server/util/crypto.py có nhắc tới cách data được chuyển đi và cách decrypt payload

```
def decrypt_data(blob: bytes, key: str) -> str:
    ciphertext = base64.b64decode(blob)
    iv = ciphertext[:16]
    ctr = Counter.new(128, initial_value=int.from_bytes(iv, byteorder="big"))
    aes = AES.new(key.encode("UTF-8"), AES.MODE_CTR, counter=ctr)
    dec = aes.decrypt(ciphertext[16:]).decode("UTF-8")
    return dec
```

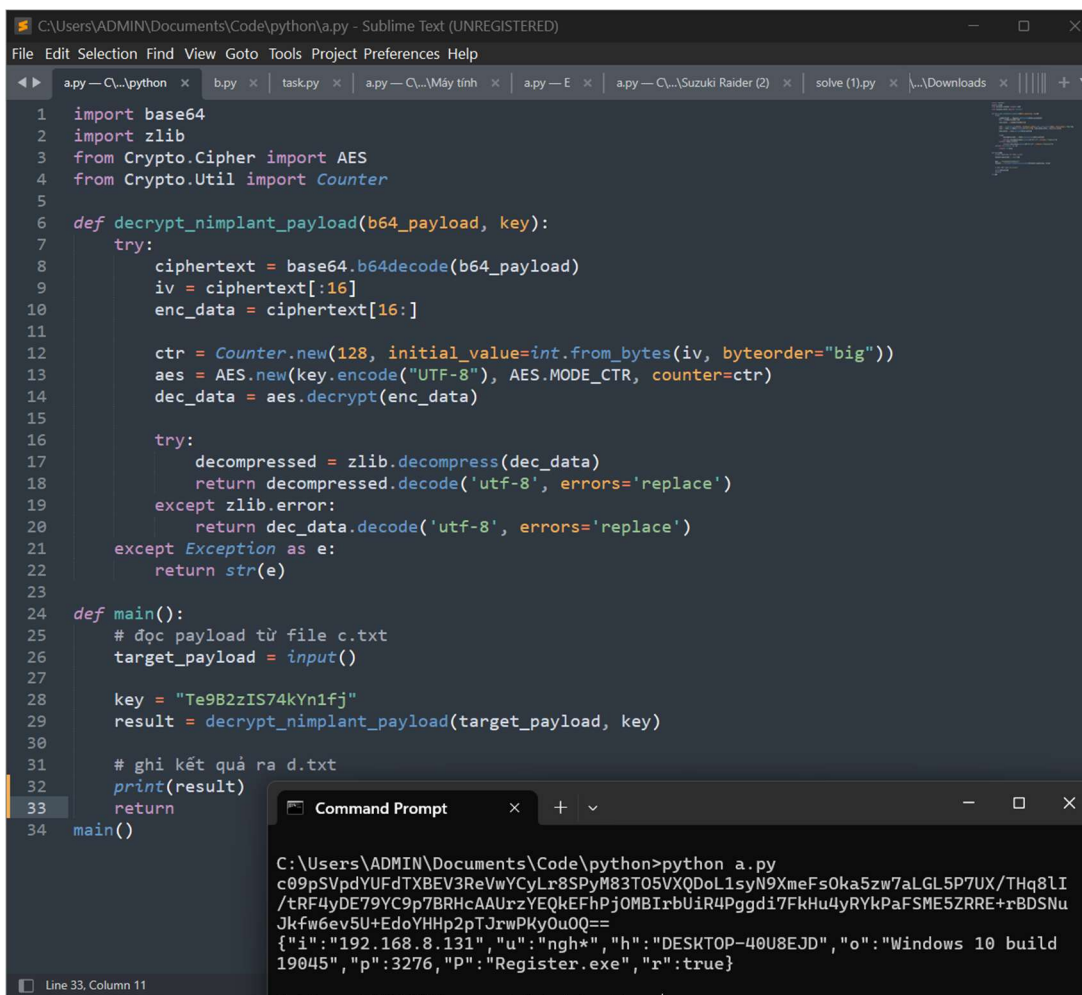
```
def decrypt_data_to_bytes(blob: bytes, key: str) -> bytes:
    ciphertext = base64.b64decode(blob)
    iv = ciphertext[:16]
    ctr = Counter.new(128, initial_value=int.from_bytes(iv, byteorder="big"))
    aes = AES.new(key.encode("UTF-8"), AES.MODE_CTR, counter=ctr)
    dec = aes.decrypt(ciphertext[16:])
    return dec
```

Nimplant C2 sử dụng phương thức mã hóa AES-CTR, sau khi decode blob, tách 16 ký tự đầu làm iv, phần còn lại là cyphertext. Vậy phần còn thiếu để decrypt là key. Đề bài còn cung cấp thêm 1 file Mini Dump, vì key ở mode AES-CTR có 16 ký tự, nên em đã dùng strings cả file .dmp, lưu vào key.txt rồi lọc những chuỗi 16 ký tự có khả năng là key với regex expression.



→ key: Te9B2zIS74kYn1fj

Từ đó, em dùng AI tạo đoạn python code tự động decrypt với input em paste vào

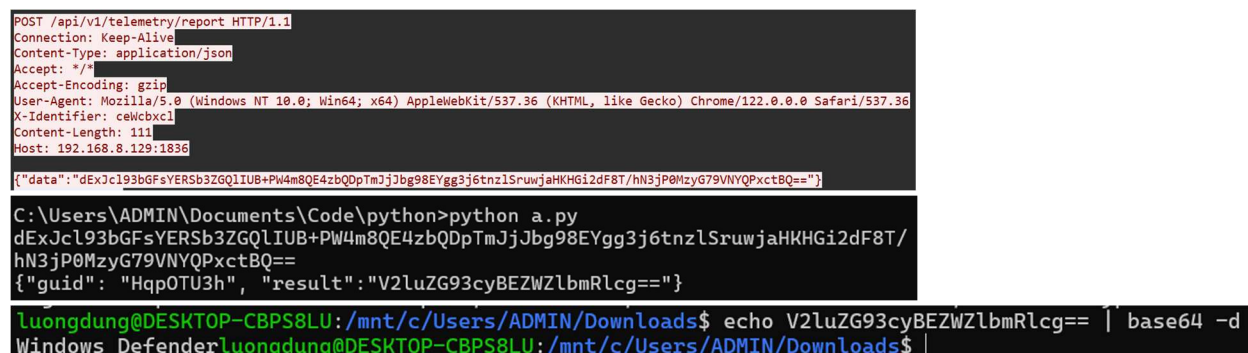


```
1 import base64
2 import zlib
3 from Crypto.Cipher import AES
4 from Crypto.Util import Counter
5
6 def decrypt_nimlant_payload(b64_payload, key):
7     try:
8         ciphertext = base64.b64decode(b64_payload)
9         iv = ciphertext[:16]
10        enc_data = ciphertext[16:]
11
12        ctr = Counter.new(128, initial_value=int.from_bytes(iv, byteorder="big"))
13        aes = AES.new(key.encode("UTF-8"), AES.MODE_CTR, counter=ctr)
14        dec_data = aes.decrypt(enc_data)
15
16        try:
17            decompressed = zlib.decompress(dec_data)
18            return decompressed.decode('utf-8', errors='replace')
19        except zlib.error:
20            return dec_data.decode('utf-8', errors='replace')
21    except Exception as e:
22        return str(e)
23
24 def main():
25     # đọc payload từ file c.txt
26     target_payload = input()
27
28     key = "Te9B2zIS74kYn1fj"
29     result = decrypt_nimlant_payload(target_payload, key)
30
31     # ghi kết quả ra d.txt
32     print(result)
33     return
34 main()
```

```
C:\Users\ADMIN\Documents\Code\python>python a.py
c09pSVpdYUfdTXBEV3ReVwYCyLr8SPyM83T05VXQDoL1syN9XmeFs0ka5zw7aLGL5P7UX/THq8LI
/trF4yDE79YC9p7BRHcAAUrzYEQkEFhPj0MBIrbUiR4Pggi7FkHu4yRYkPaFSME5ZRRE+rBDSNu
Jkfw6ev5U+EdoYHHp2pTJrwPKy0u0Q==
{"i": "192.168.8.131", "u": "ngh*", "h": "DESKTOP-40U8EJD", "o": "Windows 10 build
19045", "p": "3276", "P": "Register.exe", "r": true}
```

→ IP, hostname, OS, PID, Process của máy nạn nhân

Tiếp tục decrypt với payload có trong traffic, một số chỗ sau khi decrypt vẫn bị encode Base64, ví dụ



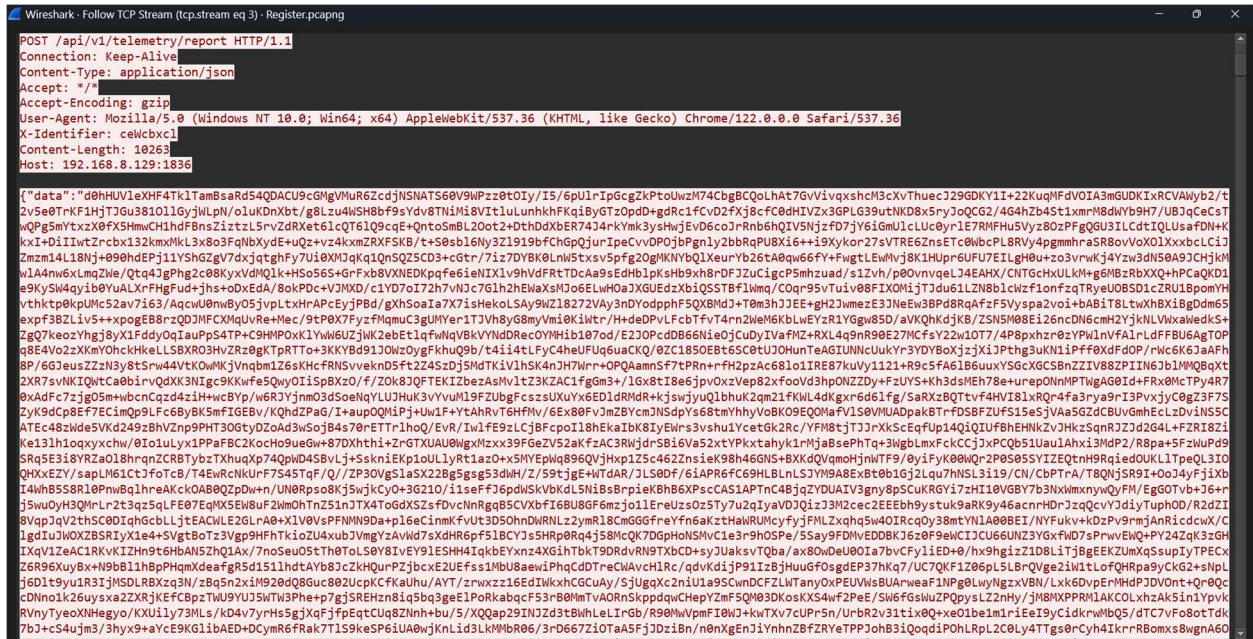
```
POST /api/v1/telemetry/report HTTP/1.1
Connection: Keep-Alive
Content-Type: application/json
Accept: */*
Accept-Encoding: gzip
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/122.0.0.0 Safari/537.36
X-Identifier: ceWcbxcl
Content-Length: 111
Host: 192.168.8.129:1836

{"data": "dExJc193bGFsYERSb3ZGQlIUB+PW4m8QE4zbQDpTmJjJg98EYgg3j6tnzLSruwjaHKHG12dF8T/hN3jP0MzyG79VNVQPxtBQ=="}

C:\Users\ADMIN\Documents\Code\python>python a.py
dExJc193bGFsYERSb3ZGQlIUB+PW4m8QE4zbQDpTmJjJg98EYgg3j6tnzLSruwjaHKHG12dF8T/
hN3jP0MzyG79VNVQPxtBQ==
{"guid": "HqpOTU3h", "result": "V2luZG93cyBEZWZlbnRlcg==" }

luongdung@DESKTOP-CBPS8LU:/mnt/c/Users/ADMIN/Downloads$ echo V2luZG93cyBEZWZlbnRlcg== | base64 -d
Windows Defenderluongdung@DESKTOP-CBPS8LU:/mnt/c/Users/ADMIN/Downloads$
```

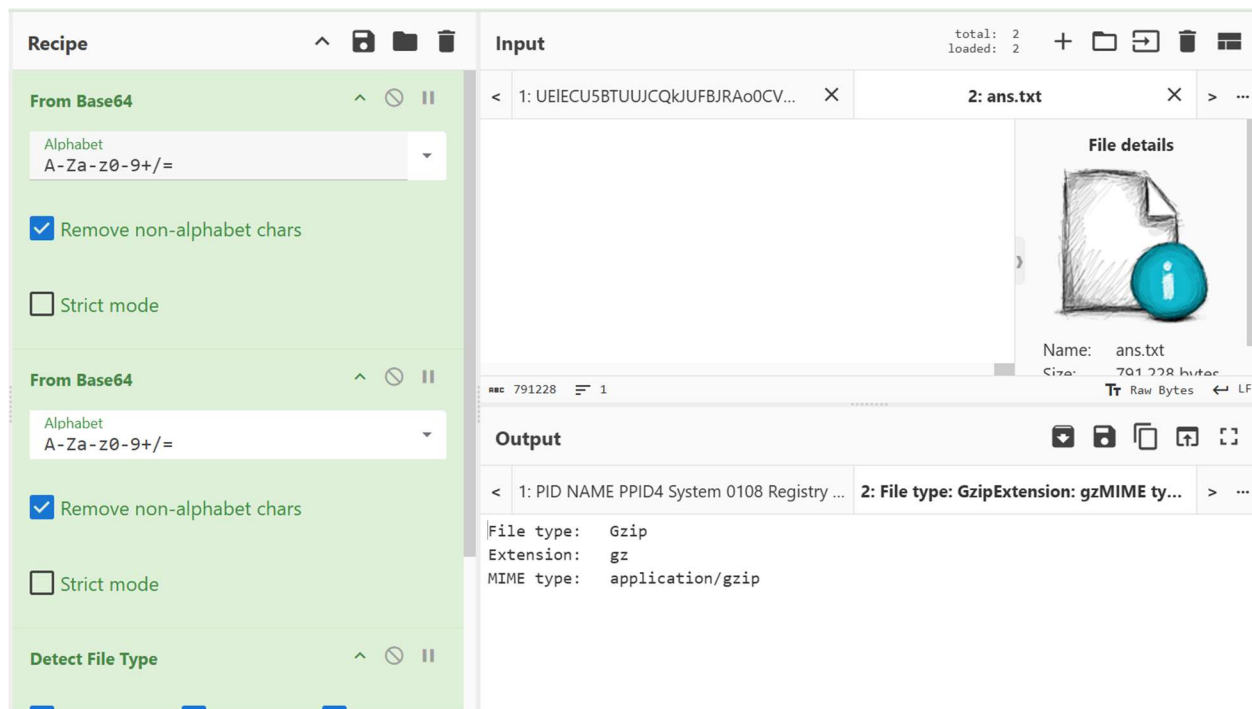
Tiếp tục decrypt cho đến



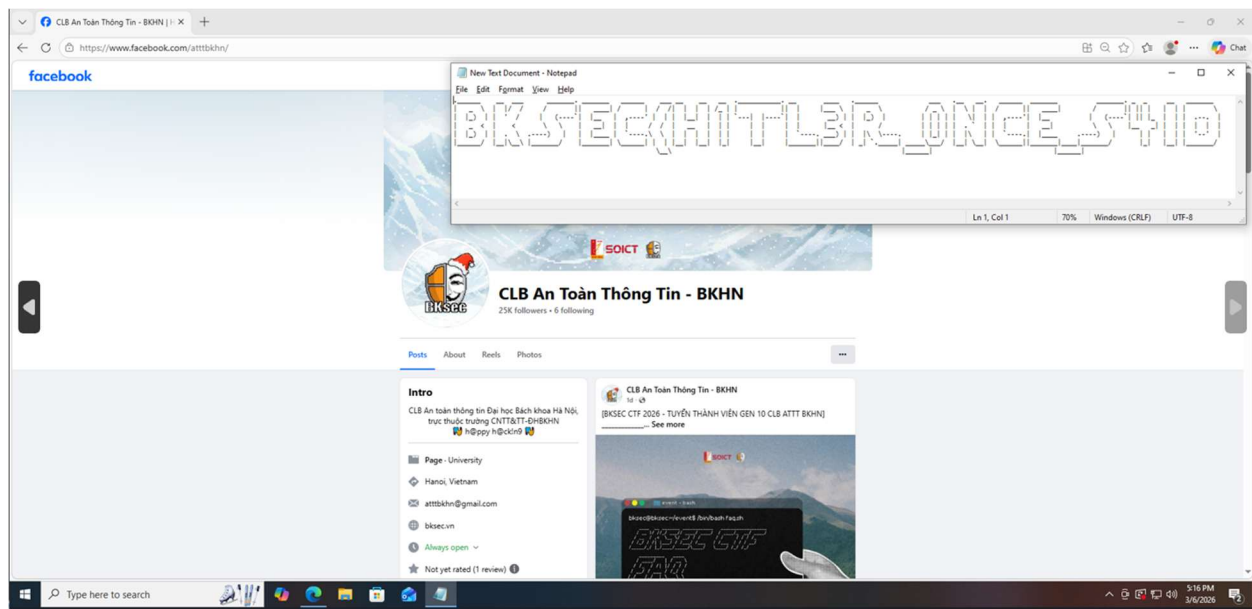
Một yêu cầu POST từ máy nạn nhân lên với Content-Length lên tới 10263, sau khi decrypt thì

```
{
  "guid": "lwV1AVBY",
  "result": "SDRzSUNBQUFBQUFBQUFEZC9YVlFYRiszQmd3bU1Ra
  VPVlZIdnpCdEgvelJ1RURLU1BiOTY4RVRoVFEzN3o4WlZXVGxMc
  FIRMJRNFA3WfCcxSskyhbKzL2htVWF1WnVmNXdxK0dPVGvKMEhMM
  NQcFA2M24xOS9scUNdV1NqaldWUC9RS1Rwc1dsV1RiWDVysF1Yd
  Urb1ZaaHQyTHE0Zj11bWZrY0xqSENRdzBOSG51b21rc0RZcWR3W
  EymHF6VXFkl0R1Rz1Xc1ZTNld1dTOGprUVZMYi820UVvnOVF2M3BCC
  0Z5NTvZ7u3Dh6cFm5Dk0a0T43u6009v43p0htvnychvYv"
}
```

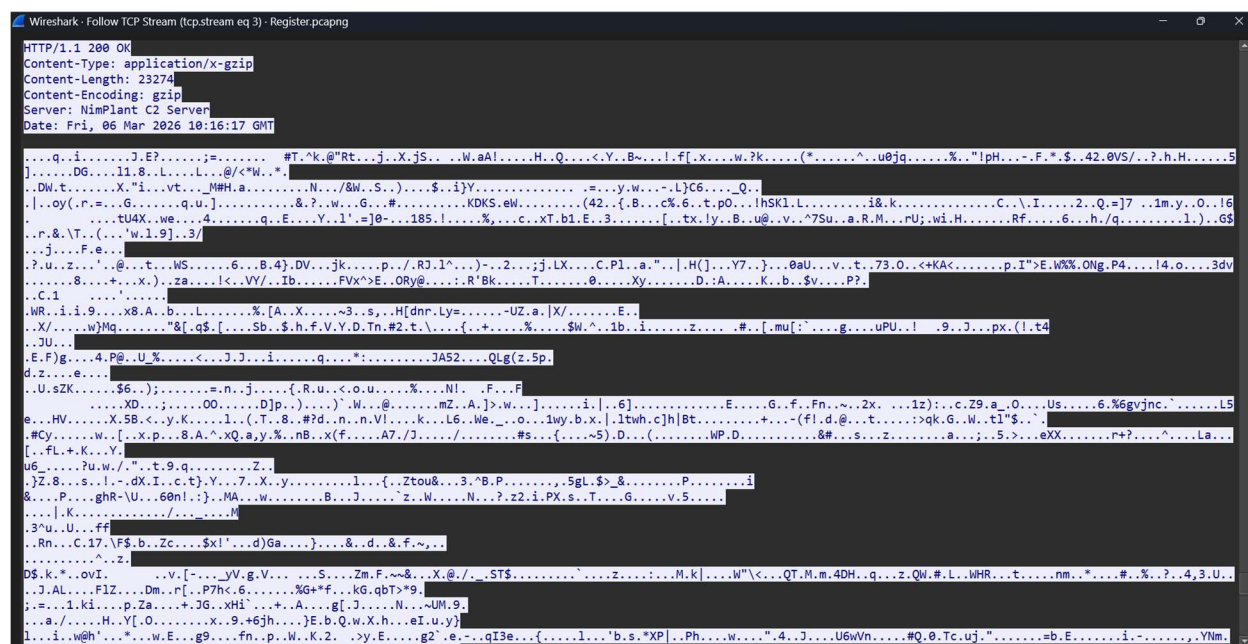
Result đã bị encode base64 (2 lần)



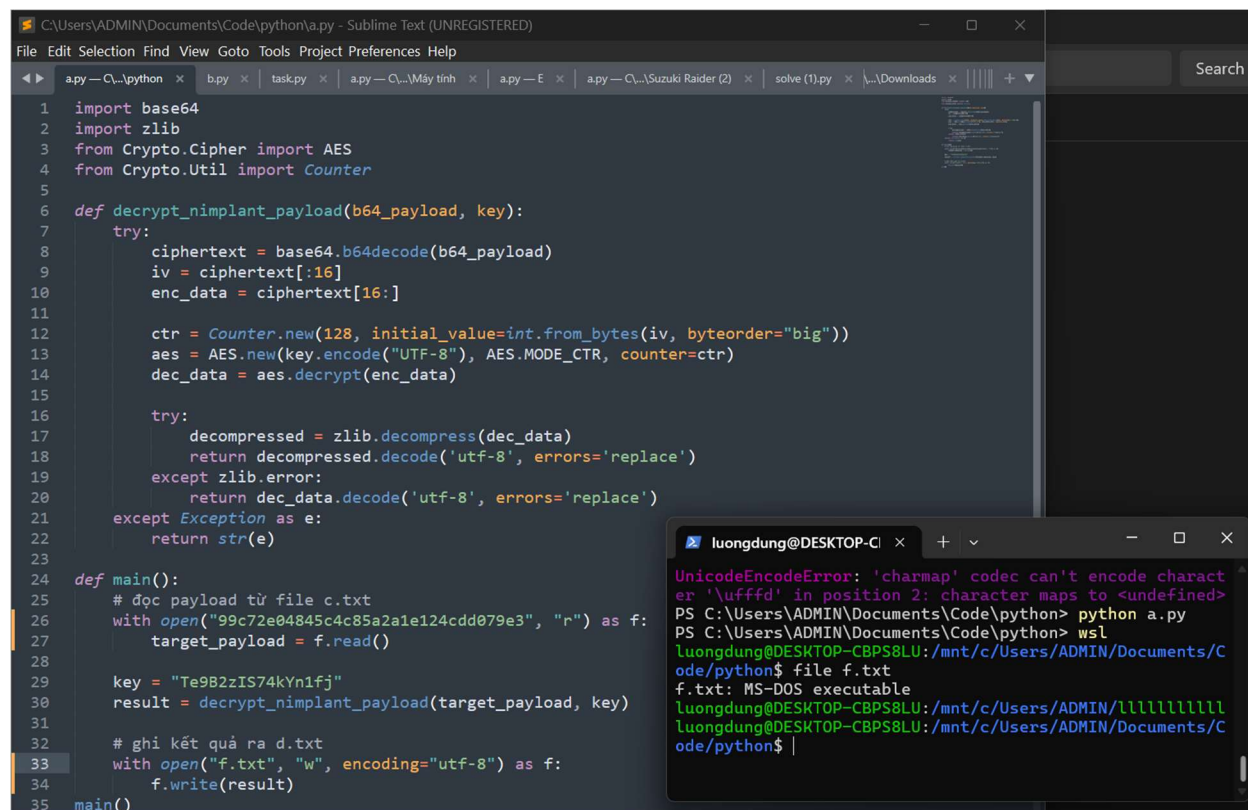
Sau khi decode Base64 2 lần thì em thu được 1 file Gzip, em lưu lại file thành sth.gz, tiến hành giải nén, em có được 1 file PNG, đổi extension thành .png và mở file em có được phần đầu của flag, ảnh PNG là ảnh được chụp màn hình



Tiếp tục decrypt, đến khi gặp phản hồi từ server với rất nhiều unreadable text



Vì không thể copy paste được như trước, em đã Extract HTTP Object rồi mới decrypt, kết quả có được sau khi decrypt là 1 file với header MZ.



Sau khi dùng lệnh strings với file f.txt, em thu được một chuỗi encode Base64 đáng ngờ

```
luongdung@DESKTOP-CBPS8LU:/mnt/c/Users/ADMIN/Documents/Code/python$ strings f.txt | grep ==  
PzM0BQxqNjEFPzM0BQhpMzkyBT8zNAUcLzIoaSh7Jw==
```

Dùng cyberchef decode Base64 và XOR Brute Force em tìm được phần còn lại của flag

The screenshot shows the CyberChef web application interface. On the left, the 'Recipe' panel is active, showing a 'From Base64' step with the alphabet 'A-Za-z0-9+/=' and 'Remove non-alphabet chars' checked. Below it is an 'XOR Brute Force' step with 'Key length' set to 1, 'Sample length' to 100, 'Sample offset' to 0, and 'Scheme' set to 'Standard'. The 'Print key' checkbox is also checked. At the bottom of the recipe panel, there is a 'BAKE!' button and an 'Auto Bake' checkbox. On the right, the 'Input' panel contains the Base64 string 'PzM0BQxqNjEFPzM0BQhpMzkyBT8zNAUcLzIoaSh7Jw=='. The 'Output' panel displays a list of keys generated by the XOR brute force attack. The key 'ein_V0lk_ein_R3ich_ein_Fuhr3r!' is highlighted in blue, indicating it is the most likely candidate for the correct key. The output panel also shows a progress bar and a 'Crib (known plaintext string...)' field.

→ Flag: BKSEC{H1TL3R_0NCE_S4ID_ein_V0lk_ein_R3ich_ein_Fuhr3r!}